SECCIÓN 5.7

Falsos positivos, actividad legítima y validación de alertas

Temas de esta sección:

- Qué es un falso positivo (y qué no lo es)
- Falso positivo vs benigno confirmado vs actividad esperada vs fuera de política
- Actividad legítima ≠ actividad segura · Alerta correcta, conclusión incorrecta
- Por qué se generan falsos positivos
- Qué validar antes de cerrar: tickets, cambios, usuarios, herramientas
- Cómo validar alertas generadas por IA o modelos de comportamiento
- Cómo documentar: falso positivo, parcial, legítimo pero riesgoso

5.7 | Qué es un falso positivo — y qué no lo es

La definición importa: usar mal el término puede llevar a cerrar casos que no deberían cerrarse:

Falso positivo (FP)

La alerta se activó, pero la actividad detectada NO es maliciosa ni representa riesgo real.

✔️ La regla funcionó correctamente
✔️ El evento ocurrió realmente
✗ La interpretación de la regla no aplica en este contexto

Ejemplo: alerta de PowerShell sospechoso por un script corporativo de IT con ticket aprobado. El EDR detectó bien, pero el contexto muestra que es legítimo.

→ Documentar POR QUÉ es FP, no solo escribir "FP".

Lo que NO es un falso positivo

'No encontré nada' → puede ser falta de visibilidad
'No hay evidencia de compromiso' → no es lo mismo que ausencia de amenaza
'El usuario dice que era él' → no validado = no confirmado
'La alerta es muy ruidosa' → no justifica cerrar sin análisis
'Siempre dispara esta regla' → alert fatigue no es criterio de cierre

Cerrar como FP sin evidencia concreta que lo justifique es el error más costoso del SOC.

5.7 | FP, benigno confirmado, actividad esperada y fuera de política

Cuatro categorías de cierre distintas — cada una requiere distinta documentación:

FALSO POSITIVO	La alerta disparó pero la actividad es completamente legítima y esperada dentro del contexto operativo.	*Ej: Agente EDR en IT-ADM-02 con ticket aprobado genera alerta de PowerShell.*	Documentar: qué validó el FP, qué ticket o contexto lo justifica.
BENIGNO CONFIRMADO	La actividad ocurrió, no es maliciosa, pero fue confirmada directamente con el usuario o el dueño del sistema.	*Ej: Usuario confirma que descargó el archivo desde el sitio oficial del proveedor.*	Documentar: quién confirmó, cuándo, qué canal se usó.
ACTIVIDAD ESPERADA	La actividad es coherente con el rol del usuario y el contexto histórico, aunque no haya un ticket específico.	*Ej: DBA ejecuta queries complejas en horario habitual desde su workstation.*	Documentar: por qué se considera esperada, qué historial lo respalda.
FUERA DE POLÍTICA	La actividad no es maliciosa pero viola alguna política de seguridad o de uso de sistemas.	*Ej: Usuario sube archivos de trabajo a Dropbox personal sin autorización.*	Documentar: qué política aplica. Derivar al área correspondiente, no escalar a IR.

5.7 | Actividad legítima ≠ actividad segura

Que una actividad sea legítima no significa que sea segura o que no requiera acción:

LEGÍTIMA PERO RIESGOSA

```
User: proyectos.luna
Upload: 6.2 GB to Dropbox (personal)
Content: Contratos_Proveedor_2026.zip
Confirmation: User says 'it was for a supplier'
```

No hay compromiso. Pero la transferencia involucra información sensible a una cuenta personal. No es FP ni es incidente — es violación de política. Derivar a RR.HH. o a área legal.

ALERTA CORRECTA, CONCLUSIÓN INCORRECTA

```
Alert: Suspicious PowerShell
User: soporte.admin | Ticket: CHG-2026-3301
Command: install_edr_agent.ps1
Conclusion written: 'Falso positivo'
```

La alerta es correcta. La actividad es legítima y esperada. Pero la conclusión 'Falso positivo' es técnicamente incorrecta. Lo correcto es: 'Actividad autorizada'. Los FP genuinos sirven para ajustar reglas; los casos mal etiquetados generan confusión.

Legítimo ≠ seguro. Legítimo ≠ dentro de política. Categorizar bien define la respuesta correcta.

5.7 | Por qué se generan falsos positivos

Entender el origen ayuda a documentarlos correctamente y a mejorar las reglas:

Regla demasiado amplia

Causa: Alerta por cualquier PowerShell, sin considerar padre ni parámetros.

Mejora: Acotar la regla con condiciones adicionales: padre, ruta, parámetros.

Falta de contexto operativo

Causa: Alerta de despliegue de software no considera la ventana de mantenimiento.

Mejora: Integrar datos de ITSM/ticketing en la correlación de la regla.

Comportamiento legítimo inusual

Causa: Alerta de acceso masivo a archivos por proceso de backup en horario nocturno.

Mejora: Crear exclusión para el proceso y ruta específicos con validación periódica.

Herramienta de seguridad detectada por otra

Causa: EDR detecta comportamiento de otro EDR o scanner de vulnerabilidades.

Mejora: Whitelistar herramientas de seguridad corporativas con firma y ruta conocida.

Modelo de comportamiento sin contexto suficiente

Causa: Score alto de usuario sin historial previo (cuenta nueva o poco usada).

Mejora: Validar con el usuario o el área antes de cerrar. El modelo no tiene baseline.

Detección por nombre sin análisis técnico

Causa: Regla alerta por hash conocido de herramienta de pentesting sin ver si fue autorizada.

Mejora: Revisar si la herramienta fue autorizada (red team, pentest programado).

5.7 | Validar no es justificar — qué revisar antes de cerrar

Validar no significa buscar una excusa para cerrar rápido. Significa revisar evidencia concreta:

- ¿Hay ticket o cambio aprobado? ¿Coincide la fecha, hora, usuario y host?
- ¿La ruta del archivo es la esperada?
- ¿Hay otros hosts afectados de forma coherente?
- ¿El proceso o herramienta es corporativo? ¿Está firmado?
- ¿Hay actividad posterior sospechosa?
- ¿El host está dentro del alcance del cambio o es activo crítico?
- ¿La actividad coincide con el comportamiento histórico del usuario?
- ¿El usuario es el esperado para esa actividad?
- ¿El destino es corporativo o externo?
- ¿La fuente de validación es confiable?

⚠ **Cuanto más sensible sea el activo, más sólida debe ser la validación. Un ticket relacionado no justifica cualquier actividad.**

5.7 | Ticket válido vs ticket insuficiente

Un ticket puede reducir sospecha, pero no debe cerrar automáticamente el caso:

TICKET VÁLIDO

```
Alert: Suspicious PowerShell
User: secops.deploy
Host: APP-SRV-02
Parent: software_deploy.exe
Command: deploy_edr_agent.ps1
Time: 22:18
Ticket: CHG-2026-3301
Ventana: 22:00-23:30
Host en alcance: Sí
```

→ Cerrar como actividad autorizada.

TICKET INSUFICIENTE

```
Alert: Remote Service Created
User: soporte.admin
Source: USER-LAP-091 → DC-01
Service: WindowsUpdateCheck
Binary: C:\Windows\Temp\update.exe
Time: 03:14
Ticket: CHG-2026-3301
Problemas:
- DC-01 NO en alcance
- Horario fuera de ventana
- Origen: notebook usuario
- Binario en Temp
```

→ NO cerrar. Investigar o escalar.

5.7 | Cómo validar alertas generadas por IA o modelos de comportamiento

Los modelos de comportamiento y la IA generan alertas distintas a las reglas tradicionales:

Diferencias clave con reglas tradicionales

- No hay una condición explícita que lo disparó
- El score puede no tener evidencia técnica directa
- El modelo puede carecer de historial si la cuenta es nueva
- Una sola sesión puede no ser suficiente para el modelo
- 'Anomalía' no significa 'malicioso'

Preguntar: ¿qué comportamiento específico activó el score? ¿El modelo tiene suficiente baseline para este usuario?

Cómo validar antes de cerrar

- Revisar los eventos técnicos que alimentaron el score
- Buscar actividad posterior que confirme o descarte
- Validar con el usuario o el dueño del sistema
- Comparar con el historial del usuario
- Verificar si hay señales adicionales en otras fuentes

No cerrar como FP solo porque 'el modelo siempre falla en este usuario'. Documentar POR QUÉ el score alto no corresponde a riesgo real.

Score alto ≠ incidente. Score alto = señal que requiere análisis. La evidencia técnica siempre tiene más peso que el score.

5.7 | Cómo documentar: tres tipos de cierre

La documentación debe explicar por qué se toma cada decisión:

CIERRE COMO ACTIVIDAD AUTORIZADA / FALSO POSITIVO	
Falso positivo.	La alerta se generó por ejecución de powershell.exe con ExecutionPolicy Bypass. Se validó que el proceso fue iniciado por software_deploy.exe durante la ventana del cambio CHG-2026-3301, asociado al despliegue del agente EDR. El script ejecutado corresponde a C:\CorpScripts\deploy_edr_agent.ps1 y el host se encontraba dentro del alcance. No se identificó actividad adicional sospechosa. Se cierra como actividad autorizada.

VALIDACIÓN PARCIAL / MONITOREO	
Posible problema.	Se observó conexión HTTPS permitida desde USER-LAP-077 hacia sync-check-cloud.net cada 60 segundos. No se cuenta con visibilidad EDR para identificar el proceso en la ventana analizada. El dominio no es habitual en el entorno y no se identificó ticket. Se recomienda monitorear y ampliar validación si la actividad se repite.

LEGÍTIMO PERO FUERA DE POLÍTICA	
No es incidente.	Se observó transferencia de 6.2 GB hacia Dropbox. El usuario confirma que era para un proveedor. No hay señales de compromiso de cuenta. Sin embargo, el destino es una cuenta personal y la transferencia involucra documentos del proyecto. Se recomienda derivar según política de manejo de información.